VAPT Lab Assessment Report

Web Application & Network Service Security Testing

Name: Luv Rawal | **Roll No:** B23CSE026 | **Enrollment No:** 202302626010106
GLS University — Cyber Security Laboratory Coursework

1. Scope & Rules of Engagement

Testing was carried out within a self-contained lab environment for educational purposes, against three categories of targets:

- **Target A – DVWA (Damn Vulnerable Web Application):** hosted locally on Kali Linux (localhost), used for web application vulnerability testing.
- **Target B – FTP Service:** vsftpd 3.0.5, self-configured and hosted locally on Kali Linux (127.0.0.1), used for credential/brute-force testing.
- **Target C – Network Host (10.148.7.142):** an academic lab-assigned host used for reconnaissance exercises.

2. Methodology & Tools

- **Reconnaissance:** Nmap (SYN scan, service/version detection, OS detection, aggressive scan, traceroute, targeted port scans)
- **Web Application Testing:** DVWA (manual payload testing), Burp Suite (proxy-based request interception and modification)
- **Service Testing:** Metasploit Framework (auxiliary scanner modules)
- **Risk Scoring:** CVSS v3.1 Base Score

3. Findings

F1 – Reflected Cross-Site Scripting (XSS)

Target: DVWA — XSS (Reflected) module **CVSS v3.1:** 6.1 (Medium)

`AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N`

Description: The 'name' input parameter is reflected into the page response without output encoding. Eleven distinct payload vectors were confirmed to execute, including event-handler based payloads (onerror, onfocus, onmouseover, autofocus) and tag-based payloads (svg, iframe, body, form, meta refresh).

Remediation: Context-aware output encoding on all reflected input; implement a Content Security Policy (CSP); validate and sanitize input server-side.

F2 – Stored Cross-Site Scripting (XSS)

Target: DVWA — XSS (Stored) module (guestbook) **CVSS v3.1:** 6.4 (Medium)

`AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N`

Description: Guestbook 'Message' input is persisted and rendered to all visitors without sanitization, allowing a payload submitted once to execute against every subsequent viewer of the page.

Remediation: Sanitize and encode user-submitted content both at storage time and at render time; apply CSP to limit impact of any payload that slips through.

F3 – DOM-based Cross-Site Scripting (XSS)

Target: DVWA — XSS (DOM) module **CVSS v3.1:** 6.1 (Medium)

`AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N`

Description: Client-side JavaScript writes the 'default' URL parameter directly into the page DOM (language selector) without sanitization, allowing script execution purely on the client side with no server round-trip required for the injection itself.

Remediation: Avoid unsafe DOM sinks (innerHTML, document.write); use safe APIs (textContent, safe templating) and validate any value taken from the URL before use.

F4 – SQL Injection – Authentication/Data Exposure Bypass

Target: DVWA — SQL Injection module (Security Level: Low) **CVSS v3.1:** 8.2 (High)

`AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N`

Description: The 'id' parameter is concatenated directly into the backend SQL query. Submitting `1' OR '1'='1` returned all five user records in the database (admin, Gordon Brown, Hack Me, Pablo Picasso, Bob Smith) instead of a single matching row, confirming unauthenticated/unrestricted data exposure via boolean-based injection.

Remediation: Use parameterized queries / prepared statements exclusively; enforce least-privilege database accounts; apply strict input validation as defense in depth.

F5 – SQL Injection – Client-Side Control Bypass

Target: DVWA — SQL Injection module (Security Level: Medium) **CVSS v3.1:** 7.1 (High)

`AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N`

Description: At Medium security the application restricts the 'id' field to a dropdown list of valid IDs in the browser UI. This client-side restriction was bypassed using Burp Suite to intercept the POST request and modify the body directly to `id=1 OR 1=1`, which again returned all five user records, confirming the underlying query remains unparameterized regardless of the UI control.

Remediation: Never rely on client-side restrictions (dropdowns, disabled fields) as a security boundary; validate and parameterize on the server for every security tier.

F6 – Weak / Brute-Forceable FTP Credentials

Target: Self-hosted vsftpd 3.0.5 (127.0.0.1:21) **CVSS v3.1:** 6.5 (Medium)

`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N`

Description: A configured FTP account was found to be protected only by a short, common-pattern password. Using Metasploit's auxiliary/scanner/ftp/ftp_login module against a small username/password wordlist, valid credentials were recovered after a short automated sweep, with no account lockout or rate-limiting observed.

Remediation: Enforce a strong password policy; add account lockout / rate-limiting after repeated failed logins; prefer key-based authentication over passwords where the FTP client supports it; monitor and alert on repeated failed login attempts.

4. Findings Summary

ID	Finding	CVSS v3.1	Severity
F1	Reflected Cross-Site Scripting (XSS)	6.1	Medium
F2	Stored Cross-Site Scripting (XSS)	6.4	Medium
F3	DOM-based Cross-Site Scripting (XSS)	6.1	Medium
F4	SQL Injection	8.2	High
F5	SQL Injection	7.1	High
F6	Weak / Brute-Forceable FTP Credentials	6.5	Medium

5. Hardening Control Implemented

As a remediation exercise, an extended Access Control List (ACL 107) was configured on a lab router to restrict inbound traffic to HTTP (port 80) only, denying all other traffic by default. The control was verified in two states: ICMP (ping) traffic was blocked (timed out) after the ACL was applied, while HTTP traffic to the same host continued to succeed — confirming the filter allowed only its intended traffic class.

6. Reconnaissance Summary — Target C (10.148.7.142)

A structured Nmap reconnaissance sweep was performed, progressing from a basic scan to targeted service, OS, and script-based enumeration:

- `-sS` – TCP SYN scan
- `-sV` – service/version detection
- `-O` – OS fingerprinting
- `-A` – aggressive scan (version + OS + scripts + traceroute)
- `-p, --traceroute, -sL, -oN/-oX/-oA` – targeted port scan, path tracing, list scan, and saved output in multiple formats

Result: Port 80/tcp open, running Apache httpd 2.4.65 on Debian; host OS fingerprinted as a Linux 2.6.x-family kernel.

7. Conclusion

Testing identified six confirmed vulnerabilities across the assessed web application and network service, spanning three XSS variants, two SQL injection instances (including a client-side control bypass via proxy interception), and a weak-credential FTP finding. One hardening control (traffic-restricting ACL) was implemented and verified. Remediation guidance for each finding is provided above; applying server-side input validation, output encoding, and credential/rate-limiting controls would address the full set of findings.